EL ESLABON MAS DEBIL: DISEÑO ETICO DE UNA CAMPAÑA DE INGENIERIA SOCIAL (PARTE #1)

CNO V – SEGURIDAD INFORMÁTICA

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Juan Alejandro Pérez Ventura
180370@upslp.edu.mx

Contenido

Introducción 2
Marco teórico y fundamentación técnica 2
Tabla técnica comparativa de plataformas 3
Análisis crítico y conclusiones 4
Análisis individual 5
Bibliografía 6

Introducción

En estos tiempos actuales, el phishing se ha consolidado como uno de los vectores de ataque más utilizados dentro de los incidentes de ciberseguridad. Este tipo de ataque pertenece a la categoría de ingeniería social, en la cual el atacante busca manipular al usuario para obtener acceso a información sensible, credenciales o recursos del sistema. Debido a que estos ataques se dirigen directamente al comportamiento humano, las medidas técnicas tradicionales (firewalls, antivirus o filtros de correo) resultan insuficientes por sí solas.

La seguridad de la información se ha convertido en un elemento estratégico para las organizaciones modernas, especialmente en un entorno donde las amenazas digitales evolucionan constantemente. En dicho panorama, los ataques dirigidos a los usuarios finales representan un riesgo significativo, ya que muchas intrusiones no dependen únicamente de fallas técnicas, sino de la interacción humana con contenidos maliciosos que aparentan ser legítimos.

Marco teórico y fundamentación técnica

Desde una perspectiva técnica, estas plataformas funcionan mediante el envío de correos electrónicos diseñados para imitar ataques reales. Dichos correos pueden incluir enlaces falsos, páginas de autenticación simuladas o archivos adjuntos ficticios. El objetivo no es comprometer los sistemas, sino registrar las acciones del usuario y generar métricas que permitan evaluar el nivel de riesgo humano dentro de la organización.

Entre las métricas más relevantes utilizadas en estas plataformas se encuentran:

1. **Click Rate (tasa de clics)** Representa el porcentaje de usuarios que interactúan con enlaces o archivos presentes en un correo de phishing simulado. Esta métrica permite identificar qué tan susceptible es una organización a este tipo de ataques.
2. **Reporting Rate (tasa de reporte)** Indica el porcentaje de usuarios que identifican correctamente el correo como sospechoso y lo reportan a través de herramientas integradas en el cliente de correo. Un alto porcentaje en esta métrica refleja mayor conciencia de seguridad.
3. **Risk Score (puntaje de riesgo)** Algunas plataformas generan un indicador compuesto que mide el nivel de riesgo de cada usuario o del conjunto de la organización. Este valor se calcula considerando múltiples variables como clics, reportes, historial de interacción y progreso en programas de capacitación.

Además de las métricas, muchas plataformas integran **modelos de aprendizaje adaptativo**, donde el sistema ajusta automáticamente la dificultad de las campañas en función del comportamiento previo del usuario. De esta forma, los empleados que presentan mayor vulnerabilidad reciben entrenamientos más frecuentes o contenidos personalizados.

Finalmente, desde una perspectiva ética, la simulación de phishing debe implementarse como una herramienta educativa y no como un mecanismo punitivo. Las buenas prácticas recomiendan que las organizaciones comuniquen la existencia del programa, protejan la privacidad de los usuarios y utilicen los resultados principalmente para mejorar la capacitación y la postura de seguridad organizacional.

Tabla técnica comparativa de plataformas

Plataforma	Enfoque principal	Métricas disponibles	Integración	Características distintivas	Limitaciones
Hoxhunt	Entrenamiento adaptativo con IA	Click rate, reporting rate, risk score	Microsoft 365, Google Workspace	Uso intensivo de IA y gamificación para aprendizaje continuo	Alto costo y enfoque en empresas grandes
Proofpoint	Plataforma empresarial de seguridad y awareness	Click rate, reporting rate, riesgo organizacional	Integración fuerte con sistemas de seguridad de correo	Amplio ecosistema de seguridad y análisis de amenazas	Implementación compleja
KnowBe4	Plataforma integral de concientización	Click rate, reporting rate, Phish-prone percentage	Amplia compatibilidad con sistemas de correo	Gran biblioteca de contenidos y simulaciones	Enfoque más general que especializado
Cofense	Respuesta colaborativa ante phishing	Click rate, reporting rate	Integración con herramientas SOC y SIEM	Fuerte enfoque en reporte de usuarios y respuesta a incidentes	Menor enfoque en gamificación
Phished	Entrenamiento basado en comportamiento	Risk score, click rate	Integración con plataformas de correo empresarial	Uso de algoritmos de aprendizaje automático	Menor presencia en el mercado global
Ninjio	Capacitación mediante contenido audiovisual	Métricas de progreso de entrenamiento	Integración básica con plataformas de correo	Videos educativos estilo narrativa	Simulación de phishing limitada
Mimecast	Seguridad de correo con módulo de awareness	Click rate, reporting rate	Integración directa con su plataforma de seguridad	Integración nativa con protección de correo	Menor enfoque en entrenamiento personalizado
Infosec IQ	Plataforma educativa de seguridad	Click rate, reporting rate	Integración con sistemas empresariales	Amplia biblioteca de cursos y evaluaciones	Interfaz y automatización menos avanzadas

Análisis crítico y conclusiones

El análisis comparativo muestra que las plataformas de simulación de phishing pueden clasificarse en tres enfoques principales: plataformas centradas en **automatización y métricas**, plataformas orientadas a **entrenamiento adaptativo con inteligencia artificial**, y plataformas enfocadas en **capacitación educativa mediante contenidos formativos**.

Las soluciones como Hoxhunt y Phished destacan por utilizar modelos de aprendizaje adaptativo que ajustan las campañas según el comportamiento del usuario. Este enfoque permite mejorar el proceso de aprendizaje al ofrecer entrenamientos personalizados y simulaciones más realistas.

Por otro lado, plataformas como Proofpoint, Mimecast y Cofense están fuertemente integradas con sistemas empresariales de seguridad del correo electrónico. Estas herramientas ofrecen una ventaja importante en entornos corporativos donde se requiere integración con sistemas de monitoreo, SOC o plataformas SIEM.

En el caso de KnowBe4 e Infosec IQ, el enfoque se centra principalmente en la capacitación y concientización mediante bibliotecas extensas de contenido educativo, lo cual facilita la implementación de programas completos de formación en seguridad.

Finalmente, Ninjio adopta un enfoque más educativo mediante narrativas audiovisuales que buscan mejorar la retención de conocimientos. Sin embargo, su capacidad de simulación de phishing es más limitada en comparación con otras plataformas.

En términos generales, la elección de una plataforma depende del contexto organizacional. Las empresas con infraestructuras complejas suelen priorizar la integración con sistemas de seguridad existentes, mientras que organizaciones con menor madurez en ciberseguridad pueden beneficiarse más de plataformas enfocadas en capacitación y concientización.

Análisis individual

- ✓ **Hoxhunt**
  Se especializa en entrenamiento adaptativo mediante inteligencia artificial. La plataforma analiza el comportamiento de los usuarios y genera campañas personalizadas para mejorar su capacidad de detección de phishing. Su enfoque se basa en la gamificación y en la mejora continua del aprendizaje.
- ✓ **Proofpoint**
  Forma parte de un ecosistema empresarial de seguridad de correo electrónico. Su módulo de concientización permite realizar simulaciones de phishing y medir la respuesta de los usuarios, integrándose con otras herramientas de protección y análisis de amenazas.
- ✓ **KnowBe4**
  Es una de las plataformas más populares en el ámbito de concientización en ciberseguridad. Ofrece simulaciones de phishing junto con una amplia biblioteca de cursos, videos y materiales educativos para programas de entrenamiento corporativo.
- ✓ **Cofense**
  Su enfoque se centra en la colaboración entre usuarios y equipos de seguridad para identificar y responder a amenazas de phishing. Destaca por su capacidad de integrar reportes de usuarios con procesos de respuesta a incidentes.
- ✓ **Phished**
  Utiliza algoritmos de aprendizaje automático para analizar el comportamiento del usuario y calcular un puntaje de riesgo. Con base en estos datos, la plataforma adapta las campañas de simulación para fortalecer las áreas más vulnerables.
- ✓ **Ninjio**
  Se enfoca en la capacitación mediante contenido audiovisual con narrativa tipo serie. Su objetivo principal es mejorar la concientización de los usuarios a través de historias que muestran escenarios reales de ciberataques.
- ✓ **Mimecast**
  Integra funciones de simulación de phishing dentro de su plataforma de seguridad de correo electrónico. Esto permite combinar la protección técnica con programas de entrenamiento dirigidos a los usuarios.
- ✓ **Infosec IQ**
  Proporciona una plataforma de capacitación en seguridad con herramientas de simulación de phishing. Destaca por su catálogo de cursos y evaluaciones que complementan los programas de concientización organizacional.

Bibliografía

Proofpoint. (2024). *Simulaciones de phishing: características y ventajas*. Recuperado el 6 de marzo de 2026 de https://www.proofpoint.com/es/products/security-awareness-training/phishing-simulations/features

Mimecast. (2024). *¿Qué es la simulación de phishing?* Recuperado el 6 de marzo de 2026 de https://www.mimecast.com/es/content/phishing-simulation/

KnowBe4. (2024). *Prueba de seguridad contra el phishing (Phishing Security Test)*. Recuperado el 6 de marzo de 2026 de https://www.knowbe4.com/es/free-cybersecurity-tools/phishing-security-test

Infosec Institute. (2025). *Infosec IQ: plataforma de capacitación y simulación de phishing*. Recuperado el 6 de marzo de 2026 de https://www.infosecinstitute.com/iq/

NINJIO. (2025). *Security Awareness Training Toolkit*. Recuperado el 6 de marzo de 2026 de https://get.ninjio.com/core-four-toolkit-homepage

Mimecast. (2024). *Capacitación de concienciación sobre seguridad y phishing*. Recuperado el 6 de marzo de 2026 de https://www.mimecast.com/es/content/phishing-training/

Global Growth Insights. (2024). *Mercado de simulación de phishing: tendencias y análisis*. Recuperado el 6 de marzo de 2026 de https://www.globalgrowthinsights.com/es/market-reports/phishing-simulation-market-118063